

ICT2212

Ethical Hacking



Introduction to Ethical Hacking
A/Prof. Guo Huaqun (Linda)

Acknowledgement

- This set of slides is based on a version from Dr. Raymond Chan (Some slides developed by A/Prof. Peter Loh) and then updated by A/Prof. Guo Huaqun (Linda).

What is Ethical Hacking?



- Process of breaking into systems with professional intent
- It is Legal - permission is obtained from the target's owner
- Conforms to accepted professional standards of conduct
- Techniques used sometimes called **Penetration Testing**

Why study Ethical Hacking?

- Related Jobs:

Salary for Certification: Certified Ethical Hacker (CEH)

			How should I pay?	What am I worth?
			Price a Job	Find market worth
Overview				
Salaries				
Related Certifications				
Certified Ethical Hacker (CEH) Jobs by Salary				
Search by job title				
Job Title	Range	Average		
Cyber Security Analyst	S\$4k - S\$171k	S\$50,000		
Security Analyst	S\$3k - S\$76k	S\$49,132		
Penetration Tester	S\$4k - S\$84k	S\$58,435		
Cyber Security Engineer	S\$58k - S\$110k	S\$78,611		
Security Consultant, (Computing / Networking / Information Technology)	S\$43k - S\$88k	S\$70,200		
Information Security Specialist	S\$35k - S\$83k	S\$74,416		
Senior Security Consultant	S\$18k - S\$116k	S\$83,755		

If you don't want to find a job

Google Application Security

Home Learning **Reward Programs** Hall of Fame Research

Google VRP Patch Rewards AutoFuzz Patch Rewards Research Grants Chrome Rewards Android Rewards Google

Google Vulnerability Reward Program (VRP) Rules

We have long enjoyed a close relationship with the security research community. To honor all the cutting-edge external contributions that maintain a Vulnerability Reward Program for Google-owned web properties, running continuously since November 2010.

Services in scope

In principle, any Google-owned web service that handles reasonably sensitive user data is intended to be in scope. This includes virtual domains:

- *.google.com
- *.youtube.com
- *.blogger.com

Bugs in [Google Cloud Platform](#), Google-developed apps and extensions (published in [Google Play](#), in iTunes, or in the [Chrome Web Store](#) hardware devices ([Home](#), [OnHub](#) and [Nest](#)) will also qualify. See our [Android Rewards](#) and [Chrome Rewards](#) for other services and devices.

On the flip side, the program has two important exclusions to keep in mind:

- **Third-party websites.** Some Google-branded services hosted in less common domains may be operated by our vendors or partners (*zagat.com*). We can't authorize you to test these systems on behalf of their owners and will not reward such reports. Please read examine domain and IP WHOIS records to confirm. If in doubt, talk to us first!
- **Recent acquisitions.** To allow time for internal review and remediation, newly acquired companies are subject to a six-month blackout period sooner than that will typically not qualify for a reward.

Apple Security Bounty

Overview

Payouts

Terms and Conditions

Contact Us

Example Payouts

Bounty payments are determined by the level of access or execution obtained by the reported issue, modified by the quality of the report. Issues that are unique to designated developer or public betas, including regressions, can result in a 50% additional bonus if the issues were previously unknown to Apple. All security issues with significant impact to users will be considered for Apple Security Bounty payment, even if they do not fit the published bounty categories.

Unauthorized iCloud Account Access

\$25,000. Limited unauthorized control of an iCloud account.

\$100,000. Broad unauthorized control of an iCloud account.

Physical Access to Device: Lock Screen Bypass

\$25,000. Access to a small amount of sensitive data from the lock screen (but not including a list of installed apps or the layout of the home screen).

\$50,000. Partial access to sensitive data from the lock screen.

\$100,000. Broad access to sensitive data from the lock screen.

Objectives of Ethical Hacking

For ease of reference, we may refer to white hats as *hackers* and black-hats as *attackers* (grey hats can be either)

- Conduct authorized security-related investigations on the target systems
- Evaluate/assess target systems' security posture, report vulnerabilities found and recommend remediation/mitigation
- Deliver report as part of an overall security program

Ethical hackers possesses same skills, mindset and tools of an attacker but the attacks are done in a non-destructive manner

Penetration Test Report

- Pentest Scope and Objectives
- Record of findings during pentest
- Specific advice on how to close the vulnerabilities
- Steps to be followed by clients in future
- Delivered directly to an officer of the client organization

<https://www.offensive-security.com/reports/sample-penetration-testing-report.pdf>

Can you tell if hacking done is ethical?

What Should You Do / Not Do?

- Accessing a computer without permission is **illegal**
- Other illegal actions that are unauthorized:
 - Installing malware e.g., Trojans
 - Denial of Service attacks
- Ensure actions do not prevent customers from doing their jobs
- Ensure that there is a contract before starting

Sign a contract before pentesting!

Why the need for pentesting?

Why can't we protect our systems completely?

A Flawless System?

Flaws within software are root cause of successful attacks and exploits

More complex software gets, the harder it is to properly predict how it will react in all possible scenarios making it much harder to secure

Operating System:

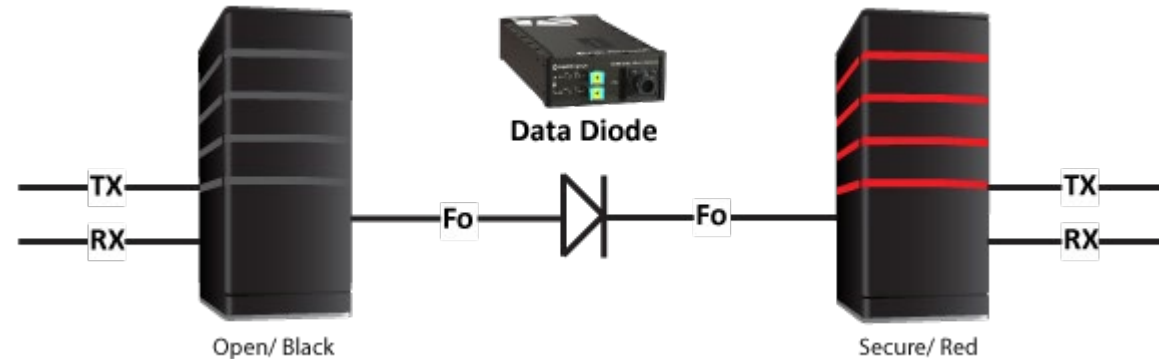
- Windows 7/10 is approximately **40/50 million lines of code**
- Linux kernel 4.1 is approximately **20 million lines of code**
- Coverity scan estimate: <1 bug per 1,000 lines of code => Windows 7 has approximately 40,000 bugs (no ISO-based standard)
- With object-oriented applications and operating systems (OSs) using each other's code, DLLs are installed and shared, many applications communicate with each other => OS cannot control this flow and provide protection against possible compromises

Critical vulnerabilities discovered in commercial security products

(<https://www.csoonline.com/article/3146046/security-products-are-among-the-most-vulnerability-riddled-software-products.html>)

- Software developers do not code securely; consumers not willing to pay more for securely developed products

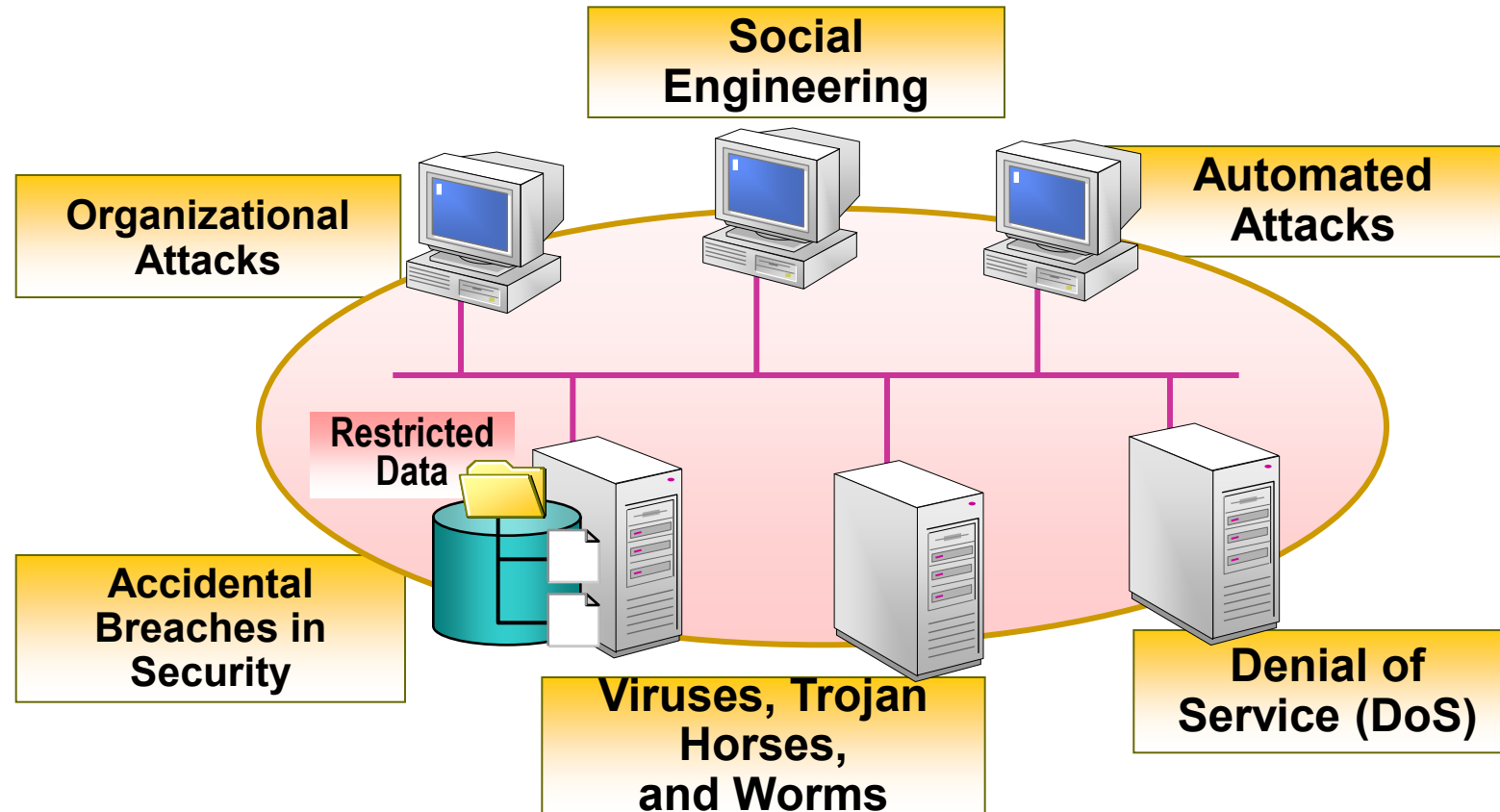
Is there an Absolute Defence?



- Many **unknown** security weaknesses including physical ones
- Attackers need to know only **one** security weakness to gain access to the system
- Admin needs to know **all** security weaknesses to completely defend the system
- Air gapping (data diodes) is a **temporary solution** – masks weaknesses, ineffective against wireless attacks, malware in USB

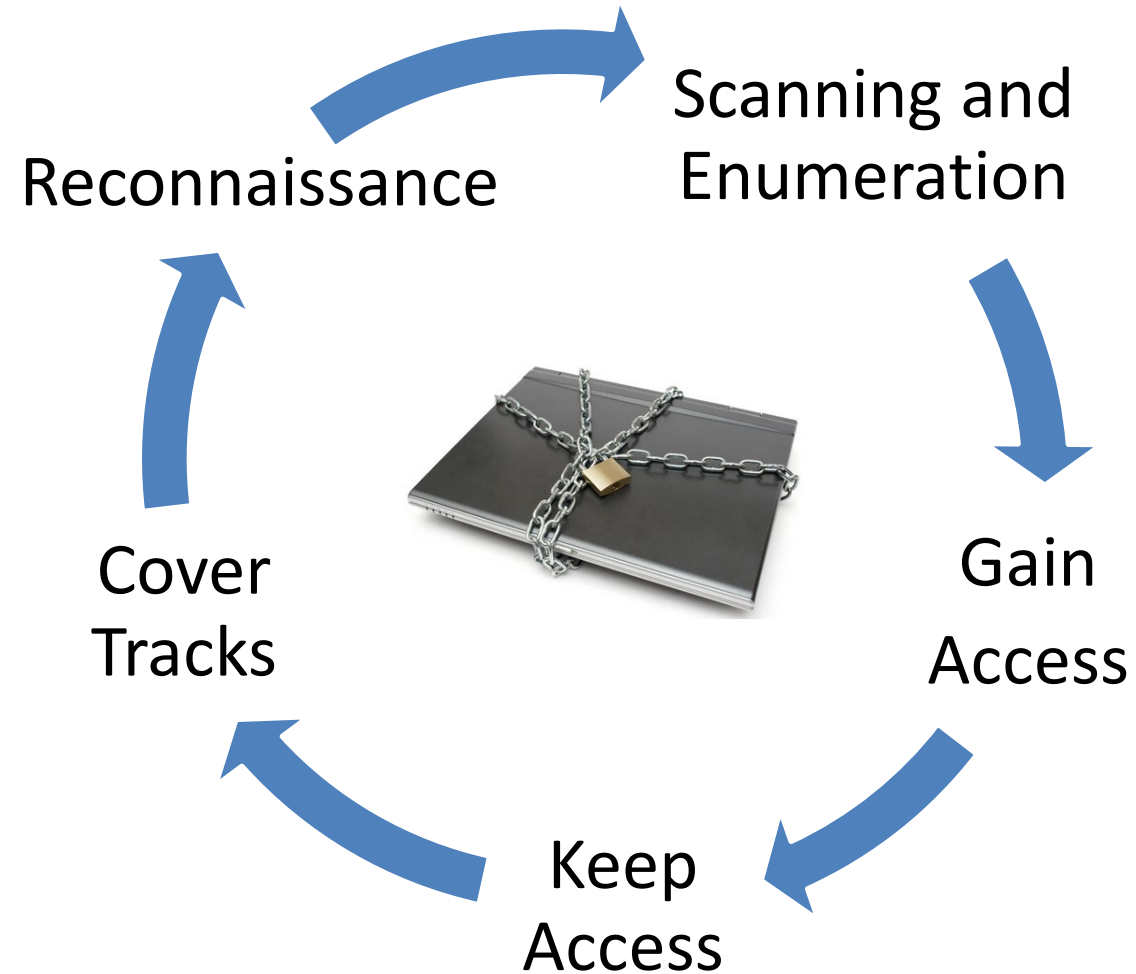
How Can Ethical Hacking Help?

Reveal Potential Internal and External Weaknesses



(Ethical) Hacking Process

Enterprise System Complexity or Existing layered Defenses require iterative execution of stages



(Ethical) Hacking Stages

1. Reconnaissance – information gathering on target
2. Scanning – use information gathered in step 1 to examine target's security posture more closely
3. Enumeration – identify user/admin accounts for use, running services etc. when attempting to gain access (**Sniffing**)
4. Gaining Access – Exploit (System, Network, Web) vulnerabilities and information from Steps 2 and 3 (**Side Channels/Privilege Escalation**)
5. Keeping or Maintaining Access – For future exploitation
6. Covering Tracks – Avoid detection (Cleanup for Ethical Hacking)

What does the (Ethical) Hacking Process Resemble?
What else do you need to do?

Reconnaissance

- Active or passive reconnaissance
- Collect as much info about targets – techniques & tools
- Identification of Targets – company websites, mail servers, OS, extranets, users info etc.
- War Driving – look for SSIDs of wireless networks in the vicinity
- Not all reconnaissance require software tools:
 - Social engineering
 - Dumpster diving



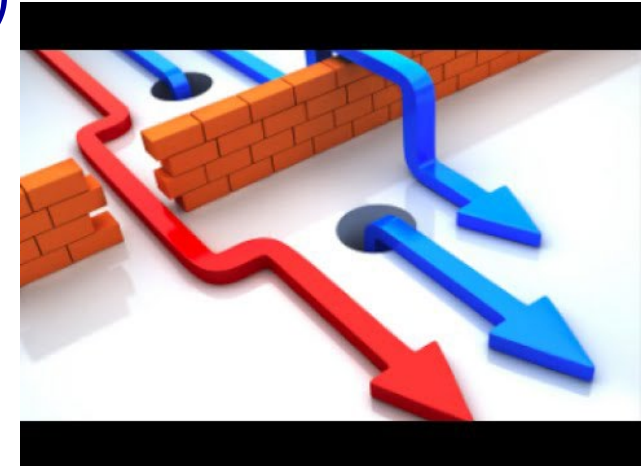
Scanning and Enumeration

- Search for and locate weaknesses for exploitation:
 - Focus on specific targets determined
 - Identification of port status, running services
 - Identify vulnerabilities e.g., open ports, vulnerable service
 - Enumeration of accounts (user, admin), operating system
 - Enumeration of NetBIOS and Windows
- Common vulnerabilities and exposures:
<http://cve.mitre.org> , <https://nvd.nist.gov/> (publicly available security vulnerability databases)
- Vulnerability Databases to Search Publicly Disclosed Security Vulnerabilities
 - cve.org, the MITRE CVE Program, National Vulnerability Database (NVD), VulnDB, CISA's Known Exploited Vulnerabilities (KEV) Catalog, GitHub Advisory Database, CISA's Open Source Vulnerabilities (OSV), Security Database



Gain Access

- Gaining normal access via located vulnerabilities
- Escalation of privileges – seek to gain complete control of system (e.g., sysadmin)
- Obtaining access to other connected systems (lateral movement)
- Payload – e.g., destructive action, info theft, ransomware
- Available Techniques and Tools:
 - Free exploits from hacker websites
 - Free customized exploits (e.g., Exploit packs from the DarkNet via TOR)
 - Use of malware e.g., Zeus
 - Use of AI e.g., PassGAN (Password Generative Adversarial Network) – machine learning based password cracking (<https://github.com/brannondorsey/PassGAN>)



Gain Access

Host System Exploits

- Authentication System Exploits
- Vulnerable File System Exploits
- Incorrect Configurations - Access Control Exploits

Application Specific Exploits

- Gaining access to insecure applications / databases – Fileless attacks
- Vulnerable web apps - SQL Injection
- Email exploits – Phishing, Spamming

Network Infrastructure Exploits

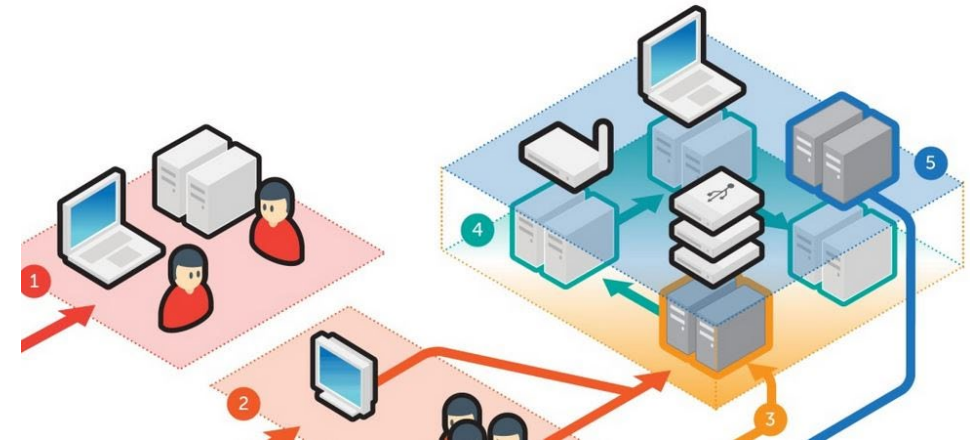
- Insecure firewall settings
- Vulnerabilities in network protocols (e.g., OpenSSL)
- Vulnerabilities to DoS or DDoS (e.g., IoT devices)

Keep (Maintain) Access

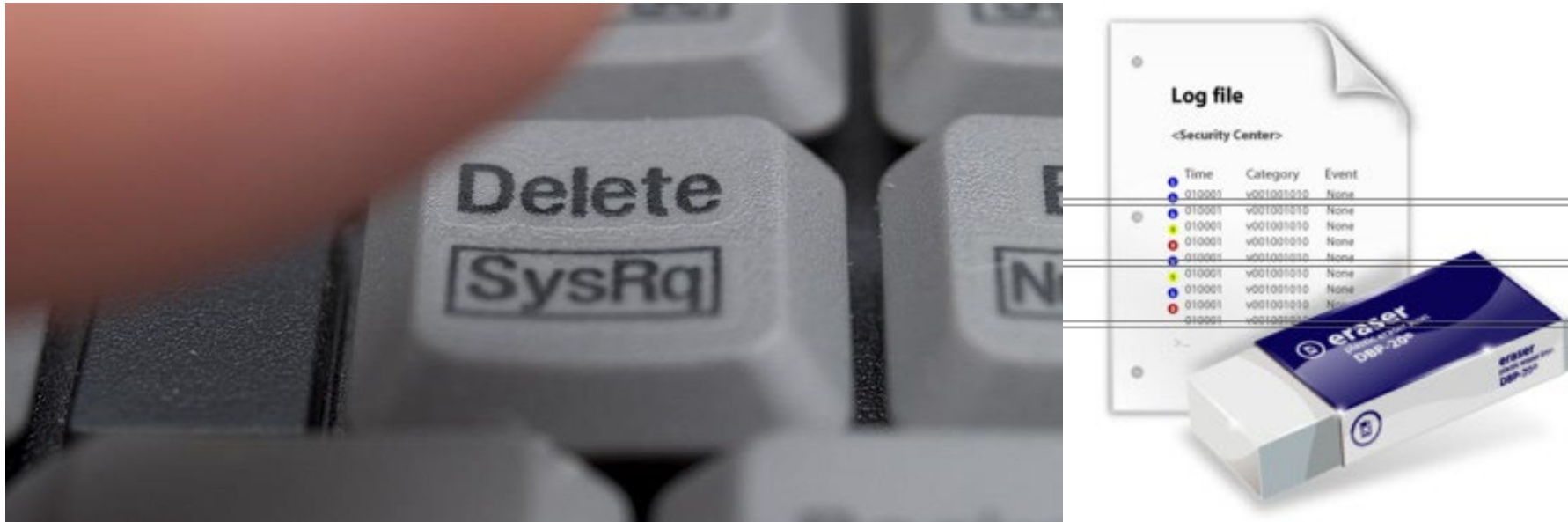
- After successful exploitation, may need to maintain access gained for further/future exploitation (lateral movement)
- Trap doors (back doors) will be laid in various parts of the system to ensure that privileged access is easily regained by the intruder

- Techniques and tools:

- Create rogue user accounts
- Schedule background batch jobs
- Plant trojans
- Install rootkits – hidden program providing target system control
- <https://github.com/d30sa1/RootKits-List-Download> (rootkits)



Cover Tracks



- Once target access is obtained and kept, attackers need to hide this fact from system administrators and ethical hackers need to clean up and restore system to original state
- Techniques and tools (minimize discovery – incomplete):
 - Clear / clean up logs
 - Delete / hide / restore files
 - Uninstall tools, malware

PHYSICAL ACCESS

Physical Access Exploits - 1

If attacker gets physical access:

- Might find logged in computer, post-it note with passwords, etc.
- Might install back door, keystroke logger, logic bomb etc.
- Could steal USB drives, laptop, computers, CDs, etc.
- Bypasses digital perimeter defenses

How does attacker gain access:

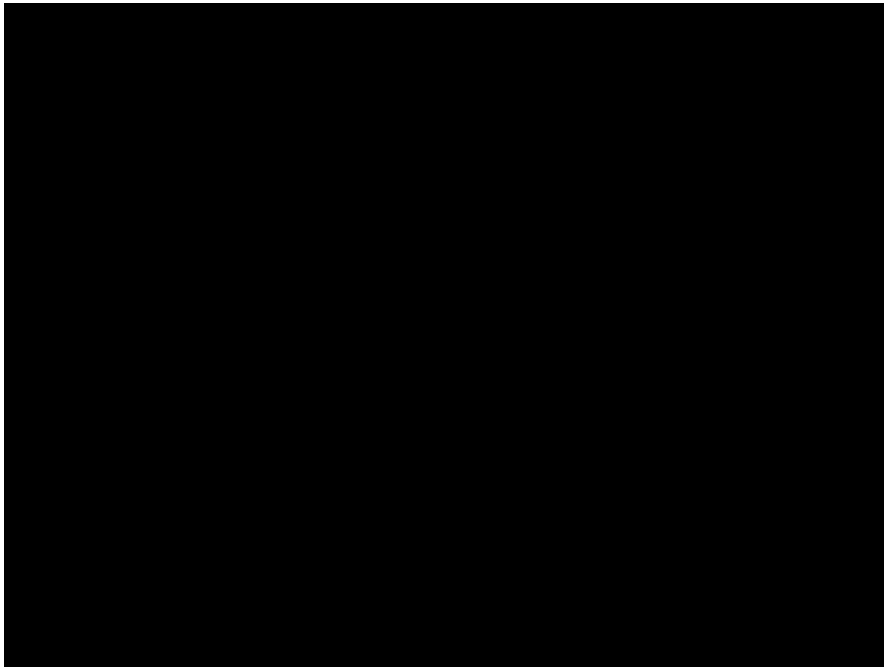
- Tailgating (partly social engineering)
- Lock bumping
- Electric lock picking
- Spoofing (social engineering)



Physical Access Exploits - 2

How does attacker gain access:

- Tailgating (partly social engineering)
- Lock bumping
- Electric lock picking
- Impostor (social engineering)



How to unlock a door



24/7 Locksmith

Home Testimonials Service Product Why Us FAQs Contact Blog

Locksmith Singapore Services - Your Lock Expert

Last Month, We Helped 216 Customers Solve Their Lock Issues

Call 8243 2440

24 hours a day, 7 days a week...

首页 > 网站地图 > 五金/工具 > 鎖具 > 特殊用鎖 > 工具 > 萬能鑰匙工具

相關推薦

鐵板工具

板手工具

葉片鎖工具

鎖工具萬能

梅花鎖工具

鐵板工具

配鎖工具

鑰匙型工具

綜合

銷量

信用

價格

一字练功锁



¥ 155

30天銷量:

多功能工具鉗子瑞士科技摺疊刀
具防身鑰匙扣隨身迷你戶外萬...

yangh_71

梅花练功锁



¥ 25

30天銷量:

新手萬能鎖區練功鎖 透明鎖 鑰
匙 工具鎖區練習用品

小蘋果9988998899



¥ 30

30天銷量:

新手鎖區通用透明鎖 梅花鎖 萬
能練功鎖 鑰匙 工具 練習技術...

小蘋果9988998899

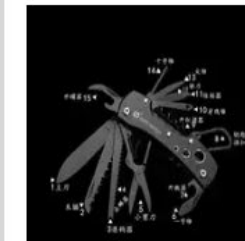


¥ 45

30天銷量:

葉片掛鎖萬能秒殺工具鑰匙維修
工具組合鎖匠工具練習常用開...

雨中漫步8620



¥ 25

30天銷量:

多功能工具鉗子瑞士科技摺疊刀
具防身鑰匙扣隨身迷你戶外萬...

文玩磁項8855



¥ 142.4

30天銷量:

十字鎖專用萬能鑰匙 工具 藍色
五隻裝用鑰匙 試開鑰匙

tb07577182



¥ 38

30天銷量:

小區管道水電井防火消防門通開
通用萬能工具替代鑰匙公用

豬豬寶禮店



¥ 25.99

30天銷量:

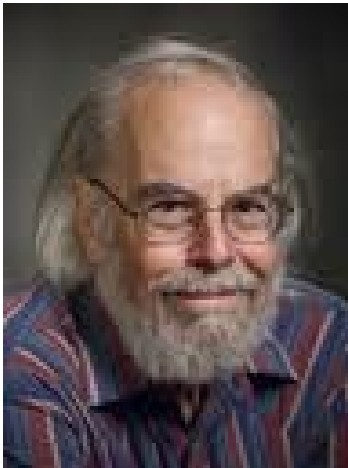
送視頻 練功鎖工具鑰匙 透明鎖
萬能練習鎖 鎖匠用品工具

yangshaoyan90

True Story – Physical Spoofing



- Person on the left looks like employee on the right
- Person on left walked around a NIST building in Washington DC unchallenged. Guards even held open doors for him to enter secure areas

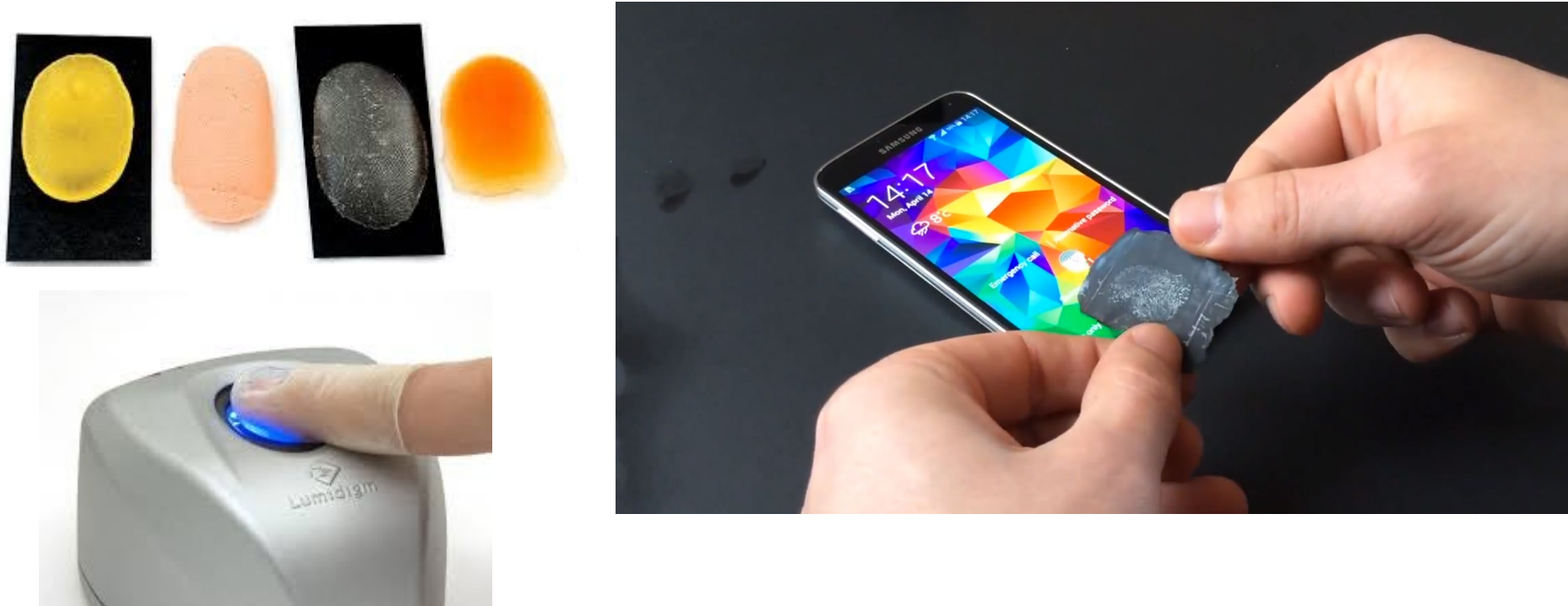


Facial Recognition Spoofing



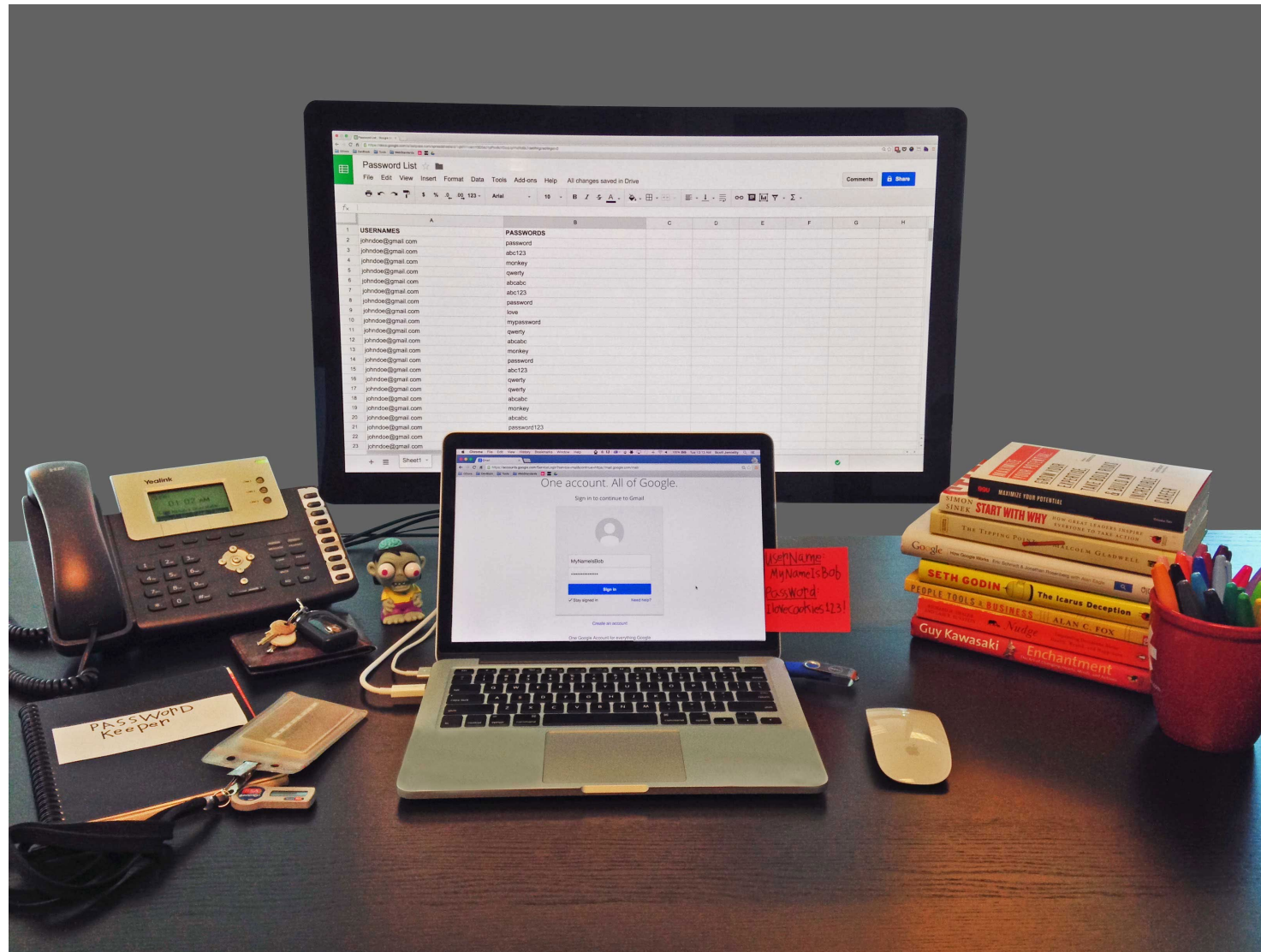
- Facial spoofing – an attack to subvert a facial recognition system
- Attacker can use someone's photo or facial video – replayed with video software
- FaceApp / Deepfake – poses security concern

Fingerprint Spoofing



- Growing usage of fingerprint authentication systems
- Hacking mobile phones using spoofed fingerprints (April 2019):
<https://www.theverge.com/2019/4/7/18299366/samsung-galaxy-s10-fingerprint-sensor-fooled-3d-printed-fingerprint>
- **How can you increase security when such a system is used?**

Exercise – Spot Any Insecurities?



Defence against Physical Access

- Require physical security policies and practices
 - E.g. badges for entry
 - RFID Systems
 - Educate staff on policies and practices / Enforce
- Biometrics for entry control
 - Iris scan, fingerprints
 - May be supplemented with CCTVs
- Use locks on file cabinets
 - Don't leave key in the lock
- Password-protection
 - Use screen shields for password / shoulder surfing
- Encrypted hard drives – eg. Bitlocker
- Monitor what people take in/out
 - Security guards and/or CCTVs
 - Laptop, USB drive, CD – BYOD policies makes this difficult

Penetration testing overview

Penetration Testing Models - 1

- White box model:
 - Tester is told everything about the target system, network topology and technology – e.g. office apps, network diagram
 - Tester is authorized to interview IT staff and other employees
 - Detailed and more focused testing possible
 - Facilitates tester's job
- Black Box Model:
 - Company staff does not know about the test
 - Tester is not given details about the network – need to discover
 - Tests if security personnel are able to detect an attack
 - Used to evaluate security posture of organization
 - Tester's job is challenging

Penetration Testing Models - 2

- Gray box model:
 - Hybrid of white and black box models
 - Company gives tester partial information
 - Provides a more focused and efficient assessment of specified aspects of a company's security posture than a black-box assessment
 - Facilitates certain aspects of tester's job and prohibits other aspects

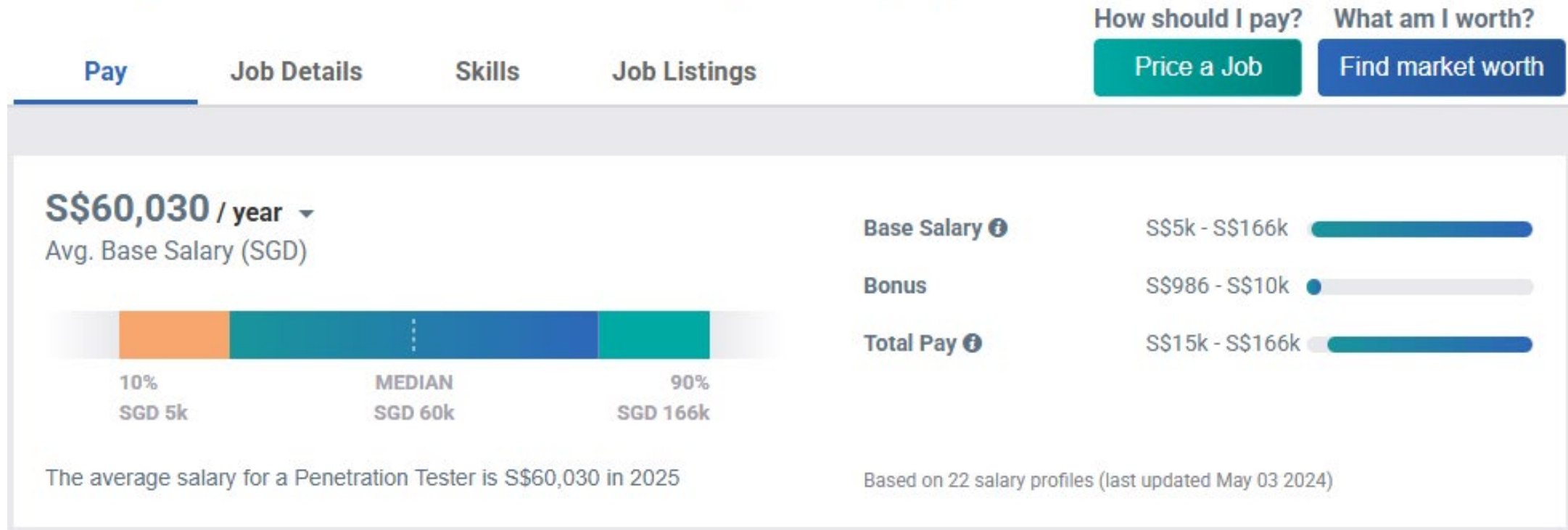
Pentester Requirements

- What it takes to be a pen tester
 - Knowledge of computer and network technologies
 - Familiarity with and ability to use necessary techniques and tools
 - Ability to communicate with management and IT personnel
 - Awareness of the laws

Average Penetration Tester Salary in Singapore

- [https://www.payscale.com/research/SG/Job=Penetration Tester/Salary](https://www.payscale.com/research/SG/Job=Penetration%20Tester/Salary)

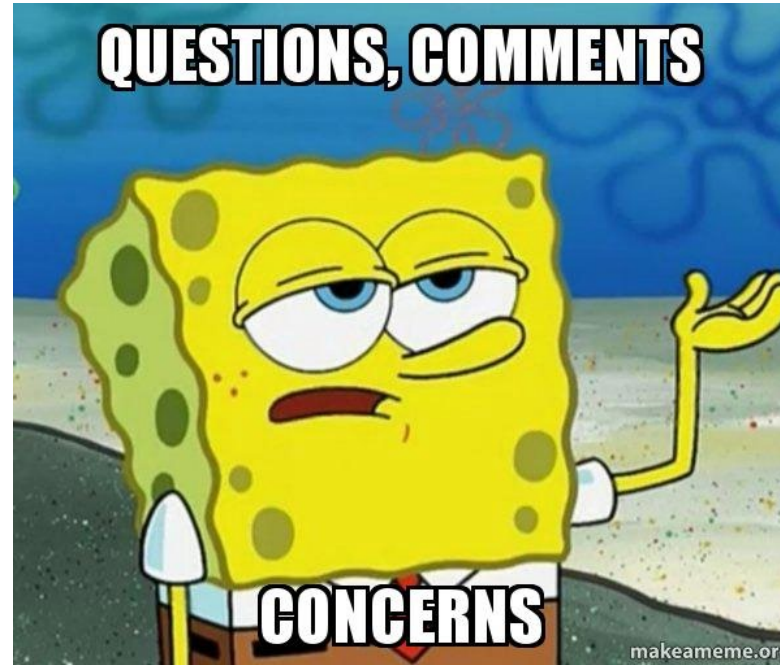
Average Penetration Tester Salary in Singapore



Summary

- Objectives of Ethical Hacking – find gaps and secure system
- Security Testing includes social engineering and physical access
- A test report:
 - Tells client what gaps you found (and how to plug them)
 - Does not tell client how you found the gaps
- What constitutes ethical / non-ethical hacking?
- Infeasibility of Absolute Defence
- Ethical Hacking Process:
 - reconnaissance, scanning and enumeration,
 - gain access, keep access and cover tracks
- Physical Access – Exploits and Defence
- Overview of Penetration Testing – black, white and gray box testing
- Professional Certifications

Next Lecture – Reconnaissance



QUESTIONS OR COMMENTS?